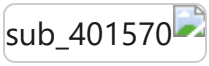
Wonderland שלב 4

בשלב הזה עבדתי ב-static analysis בלבד: לא הרצתי את Wonderland.exe ולא שיניתי קוד, רגיסטרים או זיכרון. התרגיל הזה היה מבלבל בהתחלה ולקח לי זמן להבין מה לעשות. מה-switch case הגעתי לפונקציה `sub_401570` . ראיתי שהשלב קולט **מספר** עם `scanf` , כשמחרוזת הפורמט שמופיעה ב-IDA היא בדיוק `"%du"` (ה-`%d` קורא את המספר, וה-`u` שאחריו הוא תו קבוע בפורמט). אחר כך התוכנית בונה בזיכרון מחרוזת קבועה ומשווה אותה לקלט שלי עם `strncmp` .



הפונקציה sub_401570: ה-scanf, בניית "Good luck!!" וה-strncmp

המחרוזת הקבועה שהתכנית בונה מורכבת משלושה ערכים שמועתקים לזיכרון. תרגמתי אותם מ-Little Endian ל-ASCII:

```
0x646F6F47 = "Good"
0x63756C20 = " luc"
0x0021216B = "k!!"
```

כלומר המחרוזת היא `"Good luck!!"` . הבנתי שלא צריך להכניס את המחרוזת עצמה בגלל שהקלט נקלט בתור מספר, אבל בהמשך המספר הזה נשלח ל-`strncmp` כאילו הוא מצביע למחרוזת. כלומר התוכנית לא משווה את המספר עצמו, אלא הולכת לכתובת שהמספר מייצג וקוראת משם תווים. לכן הפתרון הוא לא להקליד `Good luck!!` , אלא להכניס מספר שהוא הכתובת שבה נמצאת המחרוזת הזו בזיכרון. ושמתי לב שהמחרוזת קיימת בתוך הודעת ההצלחה `"Yeah! Good luck!! (and good job!)"` . (יש בדיקה נוספת נגד רמאות, אסור להכניס את הכתובת של ה-buffer המקומי עצמו, אחרת מקבלים "Cheater.."). חיפשתי ב-IDA איפה המחרוזת `"Good luck!!"` יושבת, פתחתי Hex view וראיתי שהיא מתחילה בכתובת `0x40473E` . תירגמתי את הכתובת לבסיס 10 במחשבון:

```
0x40473E = 4212542
```

וזה המספר שצריך להכניס:

```
4212542
```

הקטע באסמבלי שעליו התבססתי

כאן רואים את בניית `"Good luck!!"` (שלושה dwords), ואת ה-`strncmp` שמקבל את המספר שלי (`Str1`) בתור מצביע.

```
mov   dword ptr [ebp+edx+Str], 63756C20h  ; " luc"
mov   dword ptr [ebp+eax+Str], 21216Bh    ; "k!!"
mov   dword ptr [ebp+edx+Str], 646F6F47h  ; "Good"
...
mov   edx, [ebp+Str1]                     ; המספר שהוכנס
push  edx               ; Str1            ; נדחף כמצביע ל-strncmp
call  ds:strncmp
test  eax, eax
jz    short loc_401618                    ; אם שווה -> ממשיכים ל-"Yeah!"
```

זה ה-`push edx` של המספר עצמו (ולא של תוכן שנקרא ממנו) שגרם לי להבין שהמספר משמש ככתובת ולא כערך.

איך אימתתי

static בלבד, בלי להריץ את Wonderland.exe. בדקתי ב-IDA שהמחרוזת `"Good luck!!"` באמת יושבת בכתובת `0x40473E` (היא חלק מ-`"Yeah! Good luck!! (and good job!)"`). בנוסף בדקתי בכותרת ה-PE שהתוכנית ללא ASLR, כלומר הכתובות קבועות ולא זזות, ולכן מספר קבוע כמו `4212542` מצביע תמיד לאותו מקום בזיכרון.